



Unidad Didáctica

Etapas de la Auditoría, Unidad III

Contenido

Índice de Contenido	2
Introducción	3
Desarrollo de Contenidos	5
Planeación de la auditoría: definición de alcance y objetivos	5
Ejecución de la Auditoría y recolección de evidencias	14
Informe de Auditoría	24
Seguimiento del informe.....	35
Bibliografía y Webgrafía	36
Glosario	36

Introducción

En las unidades anteriores, hemos construido los cimientos de la Auditoría en Tecnologías de Información. La Unidad I nos proporcionó el "qué": el contexto histórico, los tipos de auditoría, el marco del control interno y el perfil del auditor. La Unidad II nos dotó del "con qué": las metodologías, estándares y marcos de referencia como COBIT, ITIL e ISO 27001 que guían el pensamiento y la evaluación del auditor.

Ahora, en esta Unidad III, titulada "Etapas de la Auditoría de TI", ensamblaremos todas esas piezas para responder al "cómo". Pasaremos de la teoría y la conceptualización a la acción práctica y estructurada. Una auditoría, por más conocimiento técnico que posea el profesional, no puede ser un ejercicio de improvisación o una simple "revisión ocular". Requiere un proceso disciplinado y metódico para garantizar que los resultados sean confiables, objetivos y, sobre todo, útiles para la organización.

Esta unidad está dedicada a desglosar, paso a paso, el ciclo de vida completo de una auditoría de TI. A lo largo de cuatro temas fundamentales, exploraremos las etapas secuenciales e interdependientes que conforman este proceso:

Planeación de la Auditoría: La etapa donde se define el rumbo. Aprenderemos a traducir las necesidades del negocio en un alcance claro, objetivos medibles y un programa de trabajo detallado que guiará todos los esfuerzos posteriores.

Ejecución y Recolección de Evidencias: Es el "trabajo de campo". Veremos cómo aplicar las técnicas de auditoría —entrevistas, observación, pruebas de cumplimiento y sustantivas— para obtener la evidencia suficiente y competente que respalde nuestras conclusiones, haciendo un uso intensivo de herramientas tecnológicas (CAATTs).

Informe de Auditoría: El producto final tangible. Estudiaremos cómo estructurar un informe que no solo enumere problemas técnicos, sino que comunique los hallazgos de manera clara y ejecutiva, aplicando los atributos de Condición, Criterio, Causa, Efecto y Recomendación para impulsar la toma de decisiones.

Seguimiento del Informe: El cierre del ciclo de mejora continua. Analizaremos el rol del auditor en la verificación de que las acciones correctivas comprometidas por la gerencia se implementen y, más importante aún, sean efectivas para mitigar los riesgos identificados.

Al finalizar esta unidad, el estudiante no solo comprenderá las fases del proceso, sino que estará en capacidad de gestionar y ejecutar una auditoría de TI de principio a fin, desde la reunión inicial con el auditado hasta la verificación final de las correcciones. En el contexto nicaragüense, donde las organizaciones demandan cada vez más transparencia, cumplimiento normativo (Ley 1042, NAGUN, normas SIBOIF) y eficiencia en el uso de los recursos tecnológicos, dominar este proceso metodológico es lo que diferencia a un revisor de sistemas de un verdadero auditor de TI, un profesional que agrega valor estratégico a la organización.

Planeación de la auditoría: definición de alcance y objetivos

Si la auditoría de TI fuera una expedición a una selva desconocida, la fase de planeación sería el mapa, la brújula y el plan de ruta. Adentrarse sin ellos es garantía de perderse, malgastar recursos y, muy probablemente, no llegar al destino deseado. En el ámbito profesional, una auditoría mal planificada es ineficiente, costosa y, lo que es peor, puede pasar por alto riesgos críticos que afecten la integridad financiera, la seguridad de la información o el cumplimiento normativo de la organización.

En este tema, exploraremos en detalle por qué la planeación es la fase más crucial del proceso de auditoría de TI y desglosaremos cada una de las actividades que la componen, desde el entendimiento inicial del negocio hasta la elaboración del programa de trabajo que guiará la fase de ejecución.

Importancia de la Planeación: El Pilar del Éxito

La planeación no es un simple trámite burocrático ni un formalismo. Es una inversión de tiempo que genera enormes beneficios a lo largo de toda la auditoría. Una planeación sólida permite:

- **Enfocar los esfuerzos:** Identificar las áreas, sistemas o procesos de mayor riesgo (enfoque basado en riesgos) para concentrar allí los recursos limitados de la auditoría, en lugar de dispersarlos en revisiones de bajo impacto.
- **Definir expectativas claras:** Establecer con precisión el alcance y los objetivos evita malentendidos con el auditado y asegura que todas las partes involucradas sepan qué se va a revisar y qué se espera lograr.
- **Garantizar la eficiencia y la cobertura:** Un programa de trabajo bien diseñado evita duplicidades, omisiones y asegura que se revisen todos los controles y riesgos relevantes de manera sistemática.

- **Seleccionar el equipo adecuado:** Permite determinar las habilidades técnicas y de auditoría necesarias para el trabajo, asegurando que el equipo cuente con el perfil idóneo.
- **Facilitar la supervisión y la calidad:** Un plan documentado sirve como punto de referencia para que los supervisores revisen el avance del trabajo y se aseguren de que se cumplen los estándares metodológicos de la firma o departamento de auditoría.

En Nicaragua, donde las organizaciones a menudo operan con presupuestos ajustados y los departamentos de TI pueden tener recursos limitados, la eficiencia que proporciona una buena planeación es aún más valiosa.

Actividades Clave de la Planeación

La fase de planeación es un proceso en sí misma, compuesto por varias actividades secuenciales e interrelacionadas. A continuación, las desglosamos una por una.

A. Entendimiento del Negocio y su Entorno de TI

Antes de evaluar los controles de un sistema, el auditor debe comprender el "por qué" y el "para qué" de ese sistema dentro de la organización. Esto implica:

- **Comprender la misión, visión y objetivos estratégicos de la organización o del área auditada.** Por ejemplo, no es lo mismo auditar el sistema de un banco cuyo objetivo principal es la confianza y seguridad de los depósitos, que el sistema de una empresa de retail cuyo objetivo es la rotación de inventario y las ventas.
- **Identificar los procesos de negocio clave que son soportados por TI.** ¿Qué procesos son críticos? (Ventas, nóminas, producción, logística, recaudación).

- **Mapear la infraestructura tecnológica y las aplicaciones relevantes para el alcance de la auditoría.** ¿Qué sistemas (ERP, CRM, Core Bancario), bases de datos, servidores y redes están involucrados?
- **Identificar el marco legal y normativo aplicable.** En Nicaragua, esto es fundamental. El auditor debe preguntarse: ¿Aplica la Ley 1042 de Protección de Datos Personales? ¿Es una entidad regulada por la SIBOIF? ¿Es una entidad pública sujeta a las NAGUN de la Contraloría General de la República? ¿Procesa pagos con tarjeta y debe cumplir PCI DSS?

Esta actividad se realiza mediante reuniones con la alta dirección y los responsables de TI, revisión de organigramas, planes estratégicos, manuales de procesos y documentación de sistemas.

B. Evaluación Preliminar de Riesgos y Definición del Enfoque

Con el conocimiento del negocio, el auditor realiza un primer análisis de riesgos de alto nivel. El objetivo es identificar las áreas o procesos que, por su criticidad o exposición a amenazas, merecen una atención prioritaria.

- **Identificación de riesgos:** ¿Qué puede salir mal en este entorno? (Ej. Acceso no autorizado a datos sensibles, fraude interno, interrupción del servicio, errores en el procesamiento de transacciones, incumplimiento legal).
- **Evaluación de criticidad:** ¿Qué activos de información son más valiosos? ¿Qué sistemas, si fallan, causarían el mayor impacto financiero, operativo o reputacional?
- **Definición del enfoque:** Con base en esta evaluación, el auditor define la estrategia de la auditoría. El enfoque más común y recomendado es el **enfoque basado en riesgos**, que consiste en dirigir los mayores esfuerzos y recursos de la auditoría hacia las áreas de mayor riesgo identificado.

C. Determinación del Alcance y los Objetivos de la Auditoría

Esta es una de las actividades más importantes de la planeación, ya que define los límites y el propósito de la auditoría.

- **Alcance:** Responde a la pregunta "**¿Hasta dónde vamos a revisar?**". Establece los límites precisos de la auditoría. Debe ser lo suficientemente específico para evitar ambigüedades. Un buen enunciado de alcance incluye:
 - **Procesos o áreas de negocio:** (Ej. "Proceso de Gestión de Accesos y Seguridad Lógica").
 - **Sistemas o aplicaciones:** (Ej. "Sistema Integrado de Gestión Financiera (SIAF)").
 - **Ubicaciones físicas:** (Ej. "Data Center principal y oficinas centrales en Managua").
 - **Período de tiempo a revisar:** (Ej. "Transacciones y configuraciones del período del 1 de enero al 31 de diciembre de 2024").
- **Objetivos:** Responde a la pregunta "**¿Qué queremos lograr con esta auditoría?**". Definen el propósito específico de la revisión. Deben ser claros y medibles. Ejemplos de objetivos:
 - *Objetivo General:* "Evaluar la efectividad del sistema de control interno sobre la seguridad lógica del sistema de nómina".
 - *Objetivos Específicos:*
 1. "Verificar que el proceso de creación, modificación y eliminación de cuentas de usuario esté formalmente definido y sea adecuadamente autorizado".
 2. "Evaluar si los permisos de acceso asignados a los usuarios son consistentes con sus funciones y responsabilidades (principio de mínimo privilegio)".
 3. "Confirmar que el sistema registre adecuadamente las actividades de los usuarios (pistas de auditoría) y que estas sean revisadas periódicamente".

D. Identificación de Criterios de Auditoría

El auditor no puede emitir un juicio basado en su opinión personal. Necesita un punto de referencia objetivo y aceptado. Los criterios de auditoría son las **normas, estándares, leyes, políticas o procedimientos** contra los cuales se comparará la evidencia recolectada para determinar si existe una desviación o hallazgo.

Ejemplos de criterios que se definen en esta fase:

- **Políticas internas:** "Política de Seguridad de la Información de la Empresa, versión 4.0, sección 5.2 sobre Control de Accesos".
- **Normativas locales:** "Norma sobre Gestión de Riesgos de Tecnologías de Información de la SIBOIF, Artículo 12".
- **Estándares internacionales:** "Anexo A.9 de la norma ISO/IEC 27001:2022 (Control de Acceso)".
- **Buenas prácticas:** "Objetivos de control del proceso DSS05 (Gestión de la Seguridad) del marco COBIT 2019".

E. Elaboración del Programa de Trabajo Detallado

El programa de trabajo es el "plan de vuelo" detallado de la auditoría. Es un documento que lista, de manera secuencial y organizada, todos los procedimientos específicos que se ejecutarán durante la fase de trabajo de campo para cumplir con los objetivos definidos.

Cada procedimiento en el programa debe incluir:

- **Descripción clara del paso a realizar:** (Ej. "Solicitar al administrador de la base de datos el listado de todos los usuarios del sistema SAP con sus roles y permisos asignados").
- **Técnica de auditoría a emplear:** (Ej. "Análisis de datos con CAATT").
- **Objetivo del procedimiento:** (Ej. "Verificar la segregación de funciones entre los usuarios que pueden crear proveedores y los que pueden autorizar pagos").
- **Responsable de ejecutarlo.**

- **Tiempo estimado para su ejecución.**
- **Referencia al papel de trabajo donde se documentará la evidencia y los resultados.**

F. Asignación de Recursos y Cronograma

Con el programa de trabajo definido, se determinan los recursos necesarios para ejecutarlo:

- **Equipo de auditoría:** Número de auditores, roles (líder, senior, junior) y habilidades técnicas requeridas (ej. conocimiento en bases de datos Oracle, en seguridad de redes, en normativa SIBOIF).
- **Presupuesto de horas:** Cálculo del total de horas requeridas para completar la auditoría, incluyendo la propia ejecución, la supervisión y la elaboración del informe.
- **Cronograma:** Establecimiento de un calendario tentativo con fechas clave: reunión de inicio, período de trabajo de campo, fecha de reunión de cierre y fecha de emisión del informe final.

G. La Carta de Encargo o Notificación de Inicio

Finalmente, antes de iniciar el trabajo de campo, se formaliza el inicio de la auditoría mediante una comunicación oficial al auditado. En el caso de auditorías externas, se denomina "Carta de Encargo" y constituye el contrato del servicio. En auditorías internas, suele ser una "Notificación de Inicio".

Este documento resume los puntos clave acordados durante la planeación:

- Objetivo y alcance de la auditoría.
- Período a auditar.
- Equipo de auditoría asignado.
- Cronograma propuesto.
- Información y apoyo logístico requerido del auditado (acceso a sistemas, documentación, espacio físico).

Ejemplo Práctico Contextualizado en Nicaragua

Imaginemos que la **Contraloría General de la República (CGR)** incluye en su plan anual de auditoría una revisión al sistema de recaudación de impuestos municipales (como el IBI) de la **Alcaldía de León**. El auditor líder designado aplicaría las actividades de planeación de la siguiente manera:

- **Entendimiento del negocio:** Se reúne con el Director de Recaudación y el responsable de TI de la alcaldía. Aprende que el sistema se llama "SITRIM" (Sistema Tributario Municipal), está desarrollado internamente y opera en un servidor local en las oficinas de la alcaldía. Su objetivo principal es gestionar el padrón de contribuyentes y registrar los pagos. Identifica que el marco normativo aplicable son las **NAGUN**.
- **Evaluación de riesgos:** Identifica que el riesgo más significativo es la **subvaluación o falta de registro de propiedades de alto valor comercial**, así como la posible **manipulación de los registros de pago** para favorecer a ciertos contribuyentes.
- **Alcance y Objetivos:**
 - **Alcance:** "El proceso de gestión de pagos del IBI, los controles de acceso y modificación de datos en el sistema SITRIM, y los procedimientos de respaldo y recuperación de la base de datos, correspondiente al período fiscal 2024".
 - **Objetivo General:** "Evaluar la confiabilidad e integridad de la información de recaudación del IBI gestionada por el sistema SITRIM, así como los controles internos asociados".
- **Criterios:** "Artículos 10 y 15 de las NAGUN relacionados con la evaluación de controles en entornos informatizados" y el "Procedimiento Interno de Recaudación de la Alcaldía de León".
- **Programa de trabajo:** Incluirá procedimientos como: 1) Solicitar el listado completo del padrón de contribuyentes y analizarlo con una herramienta de datos (ej. IDEA) para identificar posibles duplicidades u omisiones. 2) Verificar

que las modificaciones a los valores catastrales estén soportadas por resoluciones administrativas. 3) Revisar los logs del sistema para identificar accesos y modificaciones realizadas fuera del horario laboral.

- **Carta de Notificación:** Se envía al Alcalde de León, informándole del inicio de la auditoría, el equipo designado y el cronograma tentativo de 4 semanas de trabajo de campo.

Autoevaluación

A continuación, responde las siguientes preguntas para verificar tu comprensión sobre la fase de planeación de la auditoría de TI.

Pregunta 1:

¿Cuál de las siguientes actividades de la fase de planeación responde a la pregunta "¿Hasta dónde vamos a revisar?"

- a) Determinación de los objetivos.
- b) Evaluación preliminar de riesgos.
- c) Definición del alcance.
- d) Elaboración del programa de trabajo.

Pregunta 2:

Un auditor, al planificar su trabajo en una cooperativa de ahorro y crédito nicaragüense, decide enfocar la mayor parte de su tiempo y recursos a revisar la seguridad del módulo de transferencias electrónicas, ya que lo considera el área de mayor exposición a fraudes. ¿Qué tipo de enfoque está aplicando?

- a) Enfoque sistémico.
- b) Enfoque de cumplimiento.
- c) Enfoque basado en riesgos.
- d) Enfoque de controles generales.

Pregunta 3:

En el contexto de una auditoría gubernamental en Nicaragua, ¿cuál de los siguientes sería un ejemplo de "criterio de auditoría"?

- a) El informe de auditoría del año anterior.
- b) Las Normas de Auditoría Gubernamental de Nicaragua (NAGUN).
- c) El software IDEA utilizado para el análisis de datos.
- d) El bajo presupuesto del área de TI de la entidad.

Pregunta 4:

El documento que detalla, paso a paso y de manera secuencial, los procedimientos específicos que el auditor ejecutará durante el trabajo de campo se denomina:

- a) Carta de Encargo.
- b) Informe de Hallazgos.
- c) Papel de Trabajo.
- d) Programa de Trabajo.

Pregunta 5 (Caso Práctico):

Un auditor externo es contratado por una empresa de servicios BPO en Managua para realizar una auditoría de seguridad de la información. En la fase de planeación, el auditor revisa el contrato de servicios con el cliente principal, el cual exige el cumplimiento del estándar PCI DSS porque se procesan datos de tarjetas de crédito. ¿En qué actividad de la planeación el auditor incorporará el PCI DSS como referencia?

- a) En la definición del alcance.
- b) En la identificación de los criterios de auditoría.
- c) En la asignación del equipo de trabajo.
- d) En la redacción de la Carta de Encargo.

Ejecución de la Auditoría y recolección de evidencias

Una vez que el mapa ha sido trazado y la brújula calibrada en la fase de planeación, comienza la parte más activa y tangible de la auditoría: el **trabajo de campo**. Esta es la etapa donde el auditor de TI abandona el escritorio de planificación y se sumerge en el entorno real del auditado para recolectar la evidencia que sustentará sus hallazgos y conclusiones.

Si la planeación fue el diseño arquitectónico, la ejecución es la construcción del edificio. Requiere disciplina, atención al detalle y la aplicación experta de diversas técnicas y herramientas. En este tema, exploraremos cómo se lleva a la práctica el programa de trabajo, qué métodos se utilizan para obtener evidencia suficiente y competente, y cómo se documenta todo el proceso para garantizar su trazabilidad y calidad.

Ejecutando el Programa de Trabajo: Del Plan a la Acción

El programa de trabajo, elaborado durante la planeación, se convierte en la guía diaria del auditor. Sin embargo, la ejecución no es una actividad robótica. El auditor debe mantener una actitud de **escepticismo profesional**, lo que significa que, aunque siga un plan, debe estar alerta a cualquier señal de anomalía, inconsistencia o riesgo no identificado previamente que amerite ajustar el plan sobre la marcha.

La ejecución implica:

- **Coordinación con el auditado:** Solicitar formalmente la información, los accesos a sistemas y las entrevistas necesarias.
- **Aplicación secuencial de los procedimientos:** Llevar a cabo cada paso descrito en el programa de trabajo, documentando los resultados.
- **Análisis continuo de la evidencia:** No basta con recolectar datos; el auditor debe analizarlos, interpretarlos y compararlos con los criterios definidos.

- **Flexibilidad controlada:** Si durante la ejecución surge un nuevo riesgo significativo, el auditor, en consulta con su supervisor, puede modificar el programa de trabajo para profundizar en esa área.

Técnicas y Herramientas para la Recolección de Evidencias

El auditor de TI dispone de un variado arsenal de técnicas para obtener evidencia. La elección de una u otra depende del objetivo del procedimiento y de la naturaleza de lo que se está auditando. A continuación, detallamos las más relevantes.

A. Entrevistas, Cuestionarios y Observación Directa

Son técnicas fundamentales para comprender los procesos, validar información y obtener el contexto humano de los controles.

- **Entrevistas:** Conversaciones estructuradas o semiestructuradas con el personal clave (administradores de sistemas, usuarios, gerentes). Permiten al auditor obtener explicaciones sobre cómo funcionan los procesos, quiénes son los responsables y por qué se hacen las cosas de cierta manera.
 - *Ejemplo:* Entrevistar al Oficial de Seguridad de la Información de un banco para entender el proceso de respuesta ante un incidente de ciberseguridad.
- **Cuestionarios:** Listas de preguntas estandarizadas que se envían al auditado para obtener información de manera eficiente y uniforme. Son útiles para evaluar el grado de cumplimiento de un conjunto de controles en múltiples áreas.
 - *Ejemplo:* Enviar un cuestionario de control interno basado en el Anexo A de ISO 27001 a los responsables de TI para una evaluación preliminar.
- **Observación Directa:** Presenciar físicamente la ejecución de una actividad o la existencia de un control. Es una de las técnicas más poderosas, ya que permite al auditor verificar *in situ* que lo que se dice en las políticas y entrevistas realmente ocurre en la práctica.

- *Ejemplo:* Observar cómo un operador del data center realiza el procedimiento de respaldo (backup) de las bases de datos críticas y verifica que se almacenen las cintas en una caja fuerte ignífuga.

B. Revisión Documental y Análisis de Políticas

Consiste en examinar la documentación que soporta los procesos y controles de TI.

- **Documentos a revisar:** Políticas de seguridad, procedimientos operativos estándar, manuales de usuario, actas de comités (ej. Comité de Cambios), contratos con proveedores, reportes de monitoreo, planes de continuidad, etc.
- **Objetivo:** Verificar que la documentación existe, está actualizada, ha sido formalmente aprobada y refleja las prácticas reales. También se analiza si el contenido de las políticas es adecuado y está alineado con los criterios de auditoría (normas, leyes).

C. Pruebas de Recorrido (Walkthroughs)

Esta técnica es particularmente útil al inicio del trabajo de campo para confirmar el entendimiento del auditor sobre un proceso. Consiste en seleccionar una o unas pocas transacciones representativas y seguir su rastro a través del sistema y los procesos manuales asociados, desde el origen hasta el destino final.

- *Ejemplo:* Para entender el proceso de "alta de un nuevo proveedor en el sistema de cuentas por pagar", el auditor podría:
 1. Solicitar ver el formulario de solicitud de alta.
 2. Verificar quién lo autoriza y dónde queda esa autorización.
 3. Seguir el registro en el sistema ERP.
 4. Revisar si el sistema valida automáticamente los datos (ej. formato del RUC).
 5. Observar la notificación que se envía al área de compras.
- *Propósito:* Identificar los puntos de control y las posibles debilidades en el flujo.

D. Pruebas de Cumplimiento (o de Controles)

Son el corazón de la evaluación del control interno. Están diseñadas para obtener evidencia sobre si un control específico **opera de manera efectiva** durante el período auditado. El auditor no solo verifica que el control exista (ej. una política), sino que se aplique consistentemente.

- **Metodología:** Generalmente se basan en muestreo. El auditor selecciona una muestra representativa de transacciones o eventos y verifica si el control funcionó como se esperaba en cada caso.
- *Ejemplo:* El control establece que "todos los cambios al software de producción deben ser aprobados por el Comité de Cambios y registrados en un formulario específico".
 - **Prueba de cumplimiento:** El auditor selecciona una muestra de 30 cambios implementados en los últimos 6 meses. Para cada uno, verifica si existe el formulario de solicitud de cambio debidamente aprobado por el comité.

E. Pruebas Sustantivas (o de Datos)

A diferencia de las pruebas de cumplimiento, que evalúan *cómo funciona el control*, las pruebas sustantivas se enfocan en **la integridad y exactitud de los datos en sí mismos**. Se utilizan para detectar errores o irregularidades monetarias o de información, especialmente cuando los controles son débiles o como complemento a las pruebas de cumplimiento.

- *Ejemplo 1 (Analítica):* En una auditoría al sistema de nómina, el auditor compara el total de la nómina del mes actual con el del mes anterior y el presupuesto aprobado, investigando cualquier variación significativa no explicada.
- *Ejemplo 2 (Detallada):* Para verificar que los descuentos aplicados a clientes son correctos, el auditor extrae una muestra de facturas con descuento y recalcula el monto según las políticas comerciales vigentes.

F. Uso de Herramientas de Auditoría Asistidas por Computadora (CAATTs)

En la auditoría de TI moderna, el uso de software especializado no es una opción, es una necesidad. Las **Técnicas de Auditoría Asistidas por Computadora (CAATTs)** permiten al auditor analizar grandes volúmenes de datos de manera eficiente, identificando patrones, anomalías y excepciones que serían imposibles de detectar manualmente.

Algunas aplicaciones prácticas de CAATTs en el trabajo de campo incluyen:

- **Software de Análisis de Datos (ACL, IDEA, Arbutus):** Para importar archivos de bases de datos, hojas de cálculo o reportes y realizar pruebas como:
 - Búsqueda de registros duplicados (ej. pagos duplicados a un mismo proveedor por la misma factura).
 - Análisis de secuencias numéricas para detectar saltos o vacíos (ej. en números de factura, lo que podría indicar ventas no registradas).
 - Cálculo de estadísticas (promedios, desviaciones estándar) para identificar valores atípicos.
 - Cruce de archivos (ej. cruzar el padrón de empleados activos de RRHH con los usuarios activos en el sistema de nómina).
- **Scripts SQL:** Consultas personalizadas que el auditor ejecuta directamente sobre la base de datos de la aplicación para extraer conjuntos de datos específicos que no están disponibles en los reportes estándar.
 - *Ejemplo:* `SELECT * FROM usuarios WHERE fecha_ultimo_acceso < '2023-01-01' AND estado = 'ACTIVO';` para identificar cuentas de usuario que no se han usado en más de un año pero siguen activas.
- **Herramientas de Escaneo de Vulnerabilidades (Nessus, OpenVAS):** Para auditar la seguridad técnica de servidores y dispositivos de red, identificando configuraciones inseguras, parches de seguridad faltantes y vulnerabilidades conocidas.
- **Analizadores de Logs (Splunk, ELK Stack):** Para revisar de manera centralizada y eficiente los registros de eventos (logs) de múltiples sistemas

en busca de actividades sospechosas, como accesos fallidos reiterados, accesos fuera de horario laboral o modificaciones no autorizadas.

La Documentación de la Evidencia: Los Papeles de Trabajo

Cada paso dado durante el trabajo de campo debe quedar registrado en los **papeles de trabajo**. Son el conjunto de documentos (físicos o electrónicos) que el auditor prepara y obtiene, y que constituyen el **soporte probatorio** de todo el trabajo realizado, los hallazgos identificados y las conclusiones alcanzadas.

Características esenciales de unos buenos papeles de trabajo:

- **Claros:** Cualquier otro auditor (o un supervisor) debe poder leerlos y entender qué trabajo se hizo, cómo se hizo y por qué.
- **Completo:** Deben contener toda la información relevante: el objetivo del procedimiento, la fuente de la información, el período cubierto, el alcance de la muestra, los resultados obtenidos y las conclusiones del auditor.
- **Objetivos:** Deben reflejar los hechos tal como son, sin sesgos ni opiniones personales no fundamentadas.
- **Referenciados:** Cada papel de trabajo debe tener un código único (ej. "A-3", "B-12") y debe existir un índice que los relacione, facilitando la navegación y la supervisión.
- **Organizados y Seguros:** Deben archivar de manera lógica y protegerse contra accesos no autorizados o modificaciones, garantizando su integridad y confidencialidad.

Contenido típico de un papel de trabajo:

- Nombre de la auditoría y del cliente/área auditada.
- Título del procedimiento ejecutado.
- Fecha de realización y nombre del auditor.
- Descripción del trabajo realizado (ej. "Se revisó una muestra de 50 facturas...").

- Evidencia recolectada (pueden ser capturas de pantalla, extractos de archivos, notas de entrevistas, resultados de consultas SQL).
- Conclusión sobre el procedimiento (ej. "Se identificó una desviación en 3 de las 50 facturas...").
- Referencias cruzadas a otros papeles de trabajo.

Ejemplo Práctico Contextualizado en Nicaragua

Una firma de auditoría externa está realizando una auditoría financiera y de TI a una empresa textil ubicada en la **Zona Franca de Las Mercedes**, en Managua. La empresa utiliza un sistema ERP para gestionar la nómina de sus más de 2,000 operarios. Un objetivo de la auditoría es evaluar la exactitud del cálculo de horas extras, ya que representa un gasto significativo.

El equipo de auditores de TI, en la fase de trabajo de campo, ejecuta los siguientes procedimientos:

1. Entrevista y Walkthrough:

- Entrevistan al Gerente de RRHH y al Encargado de Nómina para entender el proceso: los operarios marcan su entrada y salida en relojes biométricos; el supervisor de producción aprueba semanalmente un reporte de horas extras; el sistema ERP importa los datos del reloj y aplica las reglas de cálculo del Código del Trabajo de Nicaragua.

2. Prueba de Cumplimiento (de Controles):

- Seleccionan una muestra de 40 semanas-hombre de distintos operarios y supervisores.
- Para cada una, verifican que exista el reporte de horas extras semanal aprobado por el supervisor correspondiente.
- **Resultado:** En 35 de 40 casos, el reporte está aprobado. En 5 casos, falta la firma del supervisor.

3. Prueba Sustantiva con CAATT:

- El auditor de TI, utilizando el software **ACL**, extrae del ERP la base de datos de todas las transacciones de nómina del último trimestre.
- Escribe un script en ACL para recalcular las horas extras para una muestra de 100 empleados, basándose en las horas registradas en el reloj biométrico y las reglas del Código del Trabajo.
- Cruza el resultado de su recálculo con el monto pagado por la empresa según el sistema.
- **Resultado:** Encuentra 8 casos donde el monto pagado por horas extras es superior al que corresponde según la ley. La diferencia total es de aproximadamente C\$ 15,000.

4. Documentación en Papeles de Trabajo:

- El auditor documenta todo: las notas de la entrevista (Papel de Trabajo Ref. N-1), el análisis de la muestra de aprobaciones con la indicación de los 5 casos sin firma (Ref. N-2), y el script de ACL con los resultados del recálculo y las 8 excepciones encontradas (Ref. N-3).
- En el papel de trabajo N-3, concluye: *"La prueba sustantiva reveló un error en el cálculo de horas extras en 8 de 100 casos revisados, totalizando C\$ 15,000 en pagos en exceso. Esto indica una debilidad en el control de aplicación del módulo de nómina."*

Autoevaluación

Responde las siguientes preguntas para verificar tu comprensión sobre la fase de ejecución y recolección de evidencias.

Pregunta 1:

Un auditor desea verificar si la política de "todos los cambios a programas deben ser probados por un usuario independiente antes de pasar a producción" se cumple en la práctica. ¿Qué tipo de prueba es la más adecuada?

- a) Prueba sustantiva.
- b) Entrevista.
- c) Prueba de cumplimiento.
- d) Prueba de recorrido (walkthrough).

Pregunta 2:

¿Cuál de las siguientes actividades NO es un ejemplo de una Técnica de Auditoría Asistida por Computadora (CAATT)?

- a) Ejecutar un script SQL para listar usuarios con contraseñas que no caducan.
- b) Utilizar el software ACL para identificar facturas duplicadas por número y proveedor.
- c) Entrevistar al administrador de la base de datos sobre los procedimientos de backup.
- d) Ejecutar un escaneo de vulnerabilidades con la herramienta Nessus sobre los servidores de producción.

Pregunta 3:

Durante la auditoría de un sistema de inventario, el auditor selecciona una muestra de 20 productos en el almacén, cuenta las unidades físicas y compara el resultado con el saldo que muestra el sistema. ¿Qué técnica de auditoría está aplicando?

- a) Prueba de recorrido.
- b) Observación directa.
- c) Prueba de cumplimiento.
- d) Prueba sustantiva.

Pregunta 4:

¿Cuál es la principal característica que deben tener los papeles de trabajo para que un supervisor pueda revisar el trabajo del auditor y entender exactamente qué se hizo y por qué se llegó a una conclusión?

- a) Que estén impresos en papel membretado.
- b) Que sean claros, completos y estén referenciados.
- c) Que contengan únicamente la opinión final del auditor.
- d) Que estén firmados por el auditado.

Pregunta 5 (Caso Práctico):

En una auditoría a la **Empresa Nicaragüense de Acueductos y Alcantarillados (ENACAL)**, el auditor quiere verificar que todos los nuevos medidores de agua instalados en un mes específico hayan sido registrados correctamente en el sistema de facturación. Solicita al área comercial el archivo de órdenes de instalación y lo cruza electrónicamente con la base de datos de clientes facturados en el sistema. ¿Qué combinación de técnicas está utilizando principalmente?

- a) Entrevista y Observación.
- b) Revisión documental manual y Walkthrough.
- c) Análisis de datos con CAATT y Prueba Sustantiva.
- d) Prueba de Cumplimiento y Cuestionario.

Informe de Auditoría

Después de semanas de planificación meticulosa y de un intenso trabajo de campo recolectando y analizando evidencias, el auditor de TI se enfrenta a la etapa culminante de su labor: la comunicación de los resultados. Todo el esfuerzo invertido en las fases anteriores perdería gran parte de su valor si no se materializa en un informe claro, preciso y accionable.

El informe de auditoría es el **producto final tangible** del proceso. Es el vehículo a través del cual el auditor transmite sus hallazgos, conclusiones y recomendaciones a la alta dirección, al comité de auditoría y a otras partes interesadas. Un informe mal redactado, confuso o excesivamente técnico puede hacer que incluso los hallazgos más críticos sean ignorados o malinterpretados. Por el contrario, un informe bien estructurado se convierte en una poderosa herramienta para la toma de decisiones, la mejora de los controles y la gestión de riesgos.

En este tema, exploraremos la anatomía de un informe de auditoría de TI efectivo, el crucial paso de la reunión de cierre para validar los hechos, y las características que distinguen a un informe de alta calidad.

Estructura y Contenido del Informe de Auditoría de TI

Aunque el formato exacto puede variar según las políticas de cada firma o departamento de auditoría, un informe de auditoría de TI profesional sigue una estructura lógica y estandarizada. Esta estructura asegura que toda la información relevante se presente de manera ordenada y sea fácil de localizar para los diferentes lectores.

A continuación, se detallan las secciones típicas de un informe:

A. Portada, Índice y Datos de Identificación

- **Portada:** Incluye el título de la auditoría (ej. "Informe de Auditoría de TI: Revisión de la Seguridad Lógica del Sistema de Banca en Línea"), el nombre de la organización auditada, la fecha de emisión y el nombre del auditor o firma responsable.
- **Índice:** Facilita la navegación por el documento.
- **Datos de Identificación:** Nombre del destinatario principal (ej. "Al Comité de Auditoría de la Junta Directiva"), período auditado y referencia del encargo.

B. Resumen Ejecutivo (Para la Alta Dirección)

Esta es, probablemente, la sección más leída del informe. Está dirigida a la alta dirección y a los miembros del comité de auditoría, quienes a menudo no son expertos en tecnología y necesitan comprender rápidamente el mensaje clave.

Debe ser conciso (una o dos páginas) y contener:

- **El "por qué" de la auditoría:** Una breve mención del contexto y los objetivos principales.
- **La opinión o conclusión general del auditor:** Un veredicto claro sobre la situación general del área auditada (ej. "En opinión del auditor, los controles de acceso al sistema son en general efectivos, aunque se identificaron debilidades significativas en el proceso de gestión de bajas de usuarios que requieren atención inmediata").

- **Un resumen de los hallazgos más críticos:** Solo los puntos que representan un riesgo alto para la organización, descritos en términos de impacto al negocio (no en jerga técnica).
- **Las recomendaciones clave y el plazo sugerido para su implementación.**

C. Objetivos, Alcance y Limitaciones

Esta sección establece formalmente los límites y el propósito de la auditoría, recordando al lector qué fue lo que se acordó revisar y qué quedó fuera.

- **Objetivos:** Se transcriben los objetivos definidos en la fase de planeación.
- **Alcance:** Se describe detalladamente el universo auditado (procesos, sistemas, ubicaciones, período).
- **Limitaciones al alcance:** Si durante la ejecución existió alguna restricción que impidió al auditor realizar algún procedimiento planeado (ej. "No se pudo acceder a los logs del servidor de producción por falta de permisos"), se debe declarar explícitamente en esta sección, ya que puede afectar la opinión del auditor.
- **Criterios de auditoría utilizados:** Se listan las normas, estándares y políticas contra las cuales se evaluó la evidencia (ej. ISO 27001, NAGUN, Política Interna de Seguridad).

D. Desarrollo de Hallazgos: Aplicación de los Atributos

Este es el cuerpo principal del informe. Aquí se presentan, de manera detallada y estructurada, cada una de las desviaciones o debilidades identificadas durante el trabajo de campo. Como se estudió en la Unidad II, cada hallazgo debe documentarse utilizando los cinco atributos para garantizar que sea completo y útil.

Estructura recomendada para presentar cada hallazgo:

- **Título del Hallazgo:** Un nombre corto y descriptivo (ej. "Cuentas de Usuario de Exempleados Activas en el Sistema SAP").
- **Condición (Lo que es):** Descripción fáctica de la situación encontrada, respaldada por la evidencia recolectada. Ej. *"Se identificaron 12 cuentas de*

usuario en el módulo de finanzas correspondientes a empleados que, según el registro de RR.HH., fueron desvinculados de la empresa hace más de tres meses. Estas cuentas permanecían habilitadas para iniciar sesión."

- **Criterio (Lo que debe ser):** La norma o política específica que se está incumpliendo. Ej. *"La Política de Control de Accesos de la empresa, aprobada en enero de 2023, establece en su artículo 8 que 'el área de TI deberá desactivar las cuentas de usuario dentro de las 24 horas posteriores a la notificación de desvinculación por parte de RR.HH.'."*
- **Causa (Por qué ocurre):** El origen raíz del problema identificado por el auditor. No es una excusa, sino el factor que permite que la condición exista. Ej. *"La causa identificada es la falta de un procedimiento automatizado de sincronización entre el sistema de gestión de recursos humanos y el directorio activo (Active Directory) del sistema SAP, sumado a la ausencia de revisiones periódicas manuales de las cuentas de usuario por parte del área de TI."*
- **Efecto (Qué consecuencia tiene):** El impacto real o potencial de la condición en términos de riesgos para el negocio. Debe ser claro y concreto. Ej. *"Esta situación expone a la organización al riesgo de que exempleados, con posibles intenciones maliciosas, accedan de forma no autorizada al sistema financiero, pudiendo consultar información confidencial (estados de resultados, márgenes), modificar datos de proveedores o incluso intentar realizar transacciones fraudulentas, afectando la confidencialidad e integridad de la información financiera."*
- **Recomendación (Qué hacer):** La sugerencia concreta y viable del auditor para corregir la causa raíz y eliminar la condición. Debe ser específica y estar dirigida a un responsable claro. Ej. *"Recomendamos a la Gerencia de TI que, en coordinación con la Gerencia de RR.HH., implemente un script de sincronización automática que desactive las cuentas de usuario en SAP inmediatamente después de que un empleado sea marcado como 'inactivo' en el sistema de RR.HH. Adicionalmente, se recomienda establecer un control*

compensatorio manual que consista en una revisión trimestral de todas las cuentas de usuario activas por parte de los líderes de cada área."

E. Conclusiones y Opinión del Auditor

Esta sección va más allá del detalle de los hallazgos individuales. Aquí el auditor emite un **juicio profesional global** sobre el área auditada, basándose en la totalidad de la evidencia recolectada y la severidad de los hallazgos en conjunto. Responde directamente a los objetivos planteados al inicio del informe.

- Ejemplo de conclusión general: *"Basado en el trabajo realizado, en nuestra opinión, los controles de acceso lógico al sistema de nómina son parcialmente efectivos. Si bien los controles de autenticación y autorización para el personal activo son adecuados, la debilidad significativa identificada en el proceso de gestión de bajas de usuarios representa un riesgo que debe ser mitigado a la brevedad para asegurar la confidencialidad e integridad de la información de nómina."*

F. Anexos

Se incluye información complementaria que, por su extensión o nivel de detalle técnico, no es apropiada para el cuerpo principal del informe, pero que puede ser de utilidad para ciertos lectores (ej. el equipo técnico de TI). Ejemplos de anexos: listado completo de la muestra analizada, resultados detallados de un escaneo de vulnerabilidades, glosario de términos técnicos, etc.

La Reunión de Cierre (o de Lectura de Borrador)

Antes de emitir el informe final, es una práctica profesional obligatoria y de gran valor realizar una **reunión de cierre** con los principales responsables del área auditada. En esta reunión, el auditor presenta un borrador del informe, enfocándose en los hallazgos y las conclusiones preliminares.

Objetivos de la reunión de cierre:

1. **Validar los hechos (la Condición):** Asegurarse de que no hay errores fácticos en la descripción de la situación encontrada. El auditado tiene la oportunidad de decir: "Ese dato es incorrecto, el procedimiento real es este otro". Esto evita discusiones posteriores sobre la veracidad de los hallazgos.
2. **Discutir las causas y los efectos:** A menudo, el auditado puede aportar una perspectiva valiosa sobre las causas raíz que el auditor no pudo ver, o puede estar de acuerdo o en desacuerdo con la evaluación del riesgo (efecto).
3. **Acordar las recomendaciones y los plazos de acción:** La reunión de cierre es el foro ideal para discutir la viabilidad de las recomendaciones del auditor y acordar un plan de acción realista con fechas de implementación comprometidas por la gerencia. Esto aumenta enormemente la probabilidad de que las recomendaciones se implementen.

La reunión de cierre no es una negociación de los hallazgos; el auditor mantiene su independencia de criterio. Sin embargo, es un paso fundamental de transparencia y construcción de relaciones que legitima el proceso de auditoría.

Características de un Buen Informe

Un informe de auditoría de alta calidad se distingue por cumplir con las siguientes características:

- **Preciso:** La información es exacta, verificable y está respaldada por evidencia suficiente. No hay errores fácticos.
- **Claro:** El lenguaje es sencillo y directo, evitando jerga técnica innecesaria o explicándola cuando es imprescindible. La estructura es lógica y facilita la lectura. Cualquier persona con un conocimiento medio del negocio debe poder entender el mensaje principal.
- **Conciso:** Va al grano. No incluye información superflua ni divagaciones. El resumen ejecutivo es breve y potente.
- **Constructivo:** El tono es profesional y orientado a la mejora, no acusatorio. Las recomendaciones son prácticas y están enfocadas en resolver los problemas de raíz.
- **Oportuno:** El informe se emite en un plazo razonable tras la finalización del trabajo de campo. Un informe entregado con meses de retraso pierde relevancia, ya que la situación puede haber cambiado o las acciones correctivas ya no son oportunas.

Ejemplo Práctico

Imaginemos que la firma de auditoría **Grant Thornton Nicaragua** ha completado el trabajo de campo de una auditoría al **core bancario** de una cooperativa de ahorro y crédito en la ciudad de **Matagalpa**. Uno de los hallazgos más significativos está relacionado con la falta de segregación de funciones. El auditor redacta el hallazgo de la siguiente manera para incluirlo en el informe:

Título del Hallazgo: Falta de Segregación de Funciones en la Administración del Sistema Bancario

- **Condición:** Se identificó que el usuario genérico "ADMIN-SIB", utilizado por tres personas del área de TI, tiene la capacidad técnica en el sistema para realizar todas las siguientes funciones: (1) crear nuevos clientes en el sistema, (2) modificar las tasas de interés de los productos de ahorro, (3) autorizar transferencias electrónicas y (4) modificar los registros de auditoría (logs) del sistema.
- **Criterio:** La "Norma sobre Gestión de Riesgos de Tecnologías de Información" emitida por la **SIBOIF** en su Artículo 18, así como el principio de segregación de funciones del marco COSO, establecen que las responsabilidades clave de un proceso crítico deben ser divididas entre diferentes personas para reducir el riesgo de errores o fraudes. Una misma persona no debe tener la capacidad de iniciar, autorizar y ocultar una transacción.
- **Causa:** La causa principal es la falta de definición de roles y perfiles de usuario específicos en el sistema bancario. Por conveniencia operativa y falta de personal, se ha otorgado un perfil de "superusuario" a los administradores de TI sin una evaluación formal del riesgo.
- **Efecto:** Esta situación representa un riesgo de fraude interno **alto**. Un administrador de TI, actuando solo o en colusión con otro empleado, podría crear un cliente ficticio, modificar las tasas para beneficiarlo, autorizar un

desembolso fraudulento y luego eliminar o modificar los logs para borrar cualquier rastro de la operación ilícita. Esto podría resultar en pérdidas financieras directas para la cooperativa y sus socios, además de un grave daño reputacional y posibles sanciones por parte del ente regulador (SIBOIF).

- **Recomendación:** Recomendamos a la Gerencia General y a la Gerencia de TI:

1. Realizar un análisis detallado de las funciones y responsabilidades de cada puesto de trabajo en el área de TI.
2. Configurar en el sistema bancario roles de usuario específicos (ej. "Operador de Captaciones", "Autorizador de Tasas", "Operador de Transferencias", "Auditor de Sistemas") que reflejen una adecuada segregación de funciones.
3. Eliminar el uso del usuario genérico "ADMIN-SIB" y asignar a cada empleado un usuario nominativo con los permisos estrictamente necesarios para su función (principio de mínimo privilegio).
4. Implementar un control compensatorio mientras se configuran los nuevos roles, que consista en la revisión semanal por parte del Gerente de Operaciones de un reporte de todas las actividades realizadas con el perfil de superusuario.

Autoevaluación

Responde las siguientes preguntas para verificar tu comprensión sobre la fase de comunicación de resultados.

Pregunta 1:

¿A quién está dirigido principalmente el **Resumen Ejecutivo** de un informe de auditoría de TI?

- a) A los programadores y administradores de sistemas.
- b) A la Alta Dirección y al Comité de Auditoría.
- c) A los usuarios finales de las aplicaciones.
- d) A los proveedores externos de servicios de TI.

Pregunta 2:

En la estructura de un hallazgo de auditoría, la descripción de "la norma o política que se está incumpliendo" corresponde al atributo de:

- a) Condición.
- b) Causa.
- c) Efecto.
- d) Criterio.

Pregunta 3:

¿Cuál es el objetivo principal de la reunión de cierre o lectura de borrador del informe?

- a) Cobrar los honorarios de la auditoría.
- b) Negociar con el auditado para eliminar los hallazgos más graves.
- c) Validar los hechos (condición) con el auditado y acordar un plan de acción.
- d) Definir los objetivos y el alcance de la siguiente auditoría.

Pregunta 4:

¿Cuál de las siguientes NO es una característica deseable de un buen informe de auditoría?

- a) Preciso y respaldado por evidencia.
- b) Conciso y directo al punto.

- c) Extenso, con el máximo detalle técnico posible en el cuerpo principal.
- d) Constructivo, con recomendaciones prácticas.

Pregunta 5 (Caso Práctico):

En una auditoría al sistema de planillas del **Ministerio de Salud (MINSA)**, el auditor encuentra que un mismo funcionario puede registrar la contratación de un nuevo médico y, a la vez, autorizar el pago de su salario en el sistema. El auditor sabe que las **NAGUN** establecen la necesidad de segregar funciones para prevenir fraudes. ¿Dónde ubicaría la mención a las NAGUN al redactar el hallazgo?

- a) En la Condición.
- b) En el Criterio.
- c) En la Causa.
- d) En la Recomendación.

Seguimiento del informe

Con la emisión del informe final, muchos podrían pensar que la auditoría ha concluido. El documento está redactado, las recomendaciones han sido comunicadas y la reunión de cierre ha finalizado. Sin embargo, la verdadera medida del valor de una auditoría no reside en el informe en sí mismo, sino en las **acciones correctivas que este desencadena**. Una auditoría que solo produce un informe que se archiva en un cajón es un ejercicio estéril y un desperdicio de recursos.

La fase de **seguimiento** es la que cierra el ciclo de la auditoría y transforma los hallazgos en mejoras tangibles para la organización. Es el puente que conecta las debilidades identificadas con su solución efectiva. Un auditor profesional no abandona el barco tras señalar las vías de agua; permanece para verificar que los agujeros han sido reparados y que el rumbo se ha corregido.

En este tema, exploraremos el proceso de seguimiento, el rol del auditor en esta etapa, la importancia del plan de acción de la gerencia y cómo se verifica la efectividad de las medidas implementadas.

El Plan de Acción de la Gerencia: Compromisos, Responsables y Fechas

El seguimiento no puede iniciar sin un punto de partida claro. Ese punto de partida es el **plan de acción de la gerencia**. Después de la reunión de cierre y de recibir el informe final, la gerencia del área auditada (o la alta dirección) debe elaborar un documento formal que detalle cómo, cuándo y quién implementará cada una de las recomendaciones del auditor, o bien, justificará por qué una recomendación no será implementada (asumiendo el riesgo asociado).

Un plan de acción efectivo debe contener, para cada recomendación o hallazgo significativo:

- **Descripción de la acción correctiva específica:** No basta con decir "se mejorará la seguridad". Debe ser concreta: "Se implementará una autenticación de dos factores (2FA) para todos los accesos remotos a la VPN corporativa".
- **Responsable de la implementación:** Una persona con nombre y apellido o un cargo específico (ej. "Gerente de Infraestructura de TI").
- **Fecha límite de implementación:** Un plazo realista pero comprometido (ej. "31 de marzo de 2025").
- **Recursos necesarios:** Si la acción requiere presupuesto, personal adicional o consultoría externa, debe indicarse.

El auditor de TI no es responsable de ejecutar este plan. Su responsabilidad es solicitarlo formalmente al inicio de la fase de seguimiento y utilizarlo como la base contra la cual verificará el progreso.

El Rol del Auditor en el Seguimiento: Monitoreo y Verificación

El rol del auditor durante el seguimiento es de **evaluador y verificador independiente**, no de implementador ni de supervisor de proyectos. Su función principal es responder a la pregunta: **"¿Se ha corregido la debilidad identificada y se ha mitigado el riesgo asociado?"**

El seguimiento se puede realizar de dos maneras principales:

- **Seguimiento documental o periódico:** Para recomendaciones de mediana o baja criticidad, el auditor puede solicitar evidencias documentales de la implementación en fechas acordadas (ej. "enviar la nueva política aprobada antes del 30 de junio").
- **Seguimiento en sitio (o como parte de la siguiente auditoría):** Para hallazgos de alta criticidad o que requieren una verificación técnica más profunda, el auditor puede programar una visita específica de seguimiento o

incluir una revisión de la implementación como un procedimiento obligatorio dentro del alcance de la siguiente auditoría anual.

La Verificación de la Efectividad de las Acciones Correctivas

La actividad más importante de esta fase es la **verificación de la efectividad**. No basta con que la gerencia diga "ya lo arreglamos". El auditor debe obtener evidencia objetiva de que la acción se ha implementado y, más importante aún, de que **está funcionando y ha eliminado o reducido la causa raíz del problema a un nivel aceptable**.

Este proceso implica volver a aplicar, de manera focalizada, algunas de las técnicas de auditoría vistas en la fase de ejecución:

1. **Verificar la implementación (Existencia):** ¿Se hizo lo que se dijo que se haría?
 - *Ejemplo:* Si la recomendación era "desactivar cuentas de exmpleados", el auditor solicitará un nuevo listado de usuarios activos y verificará que los usuarios previamente identificados como inactivos ya no figuren en él.
2. **Verificar la operación (Funcionamiento):** ¿Lo que se hizo funciona como se esperaba?
 - *Ejemplo:* Si la recomendación era "implementar un script automático de sincronización entre RR.HH. y el sistema", el auditor no solo verificará que el script exista, sino que revisará los logs de ejecución del script para confirmar que se ha ejecutado correctamente todos los días.
3. **Evaluar si el riesgo se ha mitigado (Efectividad):** ¿Se ha solucionado el problema de raíz?
 - *Ejemplo:* Si la debilidad era la "falta de segregación de funciones", el auditor no solo verificará que se hayan creado nuevos roles en el

sistema, sino que realizará una prueba de cumplimiento para verificar que un usuario con el rol "Operador de Captaciones" ya no puede, efectivamente, autorizar un pago.

Resultados del Seguimiento:

- **Recomendación cerrada (o resuelta):** La evidencia demuestra que la acción correctiva se implementó de manera efectiva y el riesgo ha sido mitigado. El hallazgo se da por cerrado.
- **Recomendación en proceso:** La gerencia ha presentado un plan de acción viable, ha asignado recursos y está dentro del plazo acordado para la implementación. El hallazgo permanece "abierto" y se monitoreará en el siguiente ciclo.
- **Recomendación no implementada (o inefectiva):** La fecha límite ha expirado sin que se haya tomado acción, o la acción tomada no ha solucionado el problema. En este caso, el auditor **reitera el hallazgo** en el siguiente informe de auditoría, lo que representa un punto negativo significativo para la gerencia del área auditada y una clara señal de un riesgo no gestionado.

Ejemplo Práctico

Retomemos el ejemplo del hallazgo presentado en el Tema anterior, relacionado con la falta de segregación de funciones en el core bancario de una cooperativa en Matagalpa. El informe final fue emitido el 15 de enero de 2024. La gerencia presentó un plan de acción comprometiéndose a implementar las recomendaciones antes del 30 de junio de 2024.

El auditor de **Grant Thornton Nicaragua**, como parte de su proceso de seguimiento, agenda una revisión para el 15 de julio de 2024. El auditor realiza las siguientes actividades de verificación:

1. Verificación de implementación (documental):

- Solicita y revisa la nueva "Matriz de Roles y Perfiles del Sistema Bancario". El documento está formalmente aprobado por el Gerente de TI y el Oficial de Cumplimiento.
- Solicita y revisa las pantallas de configuración del sistema bancario. Verifica que se han creado los nuevos roles ("Operador de Captaciones", "Autorizador de Tasas", "Auditor de Sistemas") y que el usuario genérico "ADMIN-SIB" ha sido **deshabilitado**.

2. Verificación de funcionamiento (prueba de cumplimiento):

- Con la autorización de la gerencia, el auditor solicita al área de TI que le muestren una cuenta de prueba con el rol de "Operador de Captaciones". El auditor intenta, desde esa cuenta, acceder a la función de "Modificar Tasas de Interés". El sistema muestra correctamente un mensaje de "Acceso Denegado".
- El auditor solicita el reporte semanal de actividades de superusuarios (el control compensatorio recomendado). Revisa las últimas 4 semanas y verifica que el Gerente de Operaciones lo ha firmado y ha anotado las revisiones realizadas.

3. Evaluación de efectividad:

- El auditor concluye que la evidencia recolectada demuestra que la causa raíz (uso de superusuario por conveniencia) ha sido abordada y que el riesgo de fraude interno por falta de segregación de funciones se ha reducido a un nivel aceptable.

Resultado final: El auditor documenta estas verificaciones en un nuevo papel de trabajo de seguimiento y actualiza el estatus del hallazgo en su base de datos de auditoría, marcándolo como "**CERRADO – IMPLEMENTACIÓN VERIFICADA**".

Este cierre exitoso demuestra a la gerencia de la cooperativa y, lo que es más importante, a la **SIBOIF** (ente regulador), que la organización toma en serio los hallazgos de auditoría y gestiona activamente sus riesgos tecnológicos. Este es el verdadero valor de la fase de seguimiento.

Autoevaluación

Responde las siguientes preguntas para verificar tu comprensión sobre la fase de seguimiento del informe de auditoría.

Pregunta 1:

¿Quién es el principal responsable de elaborar y ejecutar el plan de acción para corregir los hallazgos de una auditoría de TI?

- a) El auditor de TI.
- b) La Gerencia del área auditada.
- c) El Comité de Auditoría de la Junta Directiva.
- d) El auditor financiero externo.

Pregunta 2:

El auditor, durante la fase de seguimiento, verifica que un script automático para desactivar cuentas de usuario no solo exista, sino que se esté ejecutando correctamente según los logs del sistema. ¿Qué aspecto de la acción correctiva está verificando?

- a) La implementación (existencia).
- b) La planificación del proyecto.
- c) El funcionamiento (operación efectiva).
- d) La asignación de recursos.

Pregunta 3:

Un auditor, en su visita de seguimiento, comprueba que la fecha límite para implementar una recomendación ha expirado y que no se ha tomado ninguna acción. ¿Cuál es la acción profesional que debe tomar el auditor?

- a) Implementar él mismo la recomendación para solucionar el problema.
- b) Ignorar el tema y esperar a la siguiente auditoría anual.
- c) Reiterar el hallazgo en el próximo informe de auditoría.
- d) Modificar la fecha límite en el informe original sin consultar a la gerencia.

Pregunta 4:

¿Cuál de los siguientes NO es un resultado posible de la fase de seguimiento?

- a) Recomendación cerrada o resuelta.
- b) Recomendación en proceso.
- c) Recomendación no implementada o inefectiva.
- d) Recomendación eliminada del informe por petición del auditado.

Pregunta 5 (Caso Práctico):

La **Dirección General de Ingresos (DGI)** de Nicaragua realizó una auditoría a su sistema de facturación electrónica y encontró que los respaldos de la base de datos se realizaban semanalmente, pero nunca se probaba su restauración. La recomendación fue: "Realizar una prueba de restauración completa de la base de datos en un ambiente de pruebas al menos una vez al trimestre". Seis meses después, el auditor de seguimiento de la DGI visita al área de TI. ¿Cuál de las siguientes evidencias le proporcionaría la mayor seguridad de que la recomendación ha sido implementada de manera **efectiva**?

- a) Un correo del Gerente de TI indicando que "ya se hacen las pruebas".
- b) Una política de respaldos actualizada que incluye el párrafo de la recomendación.
- c) Los logs del sistema que muestran que los backups se siguen haciendo semanalmente.
- d) Un acta firmada y fechada, acompañada de capturas de pantalla del proceso de restauración realizado en el ambiente de pruebas, documentando que la base de datos se restauró con éxito y en un tiempo razonable.

Evaluación Integral

Esta evaluación tiene como propósito verificar la comprensión y aplicación de los conceptos fundamentales abordados en la Unidad III. A lo largo de cuatro temas, hemos explorado:

- La Planeación de la Auditoría de TI: definición de alcance y objetivos.
- La Ejecución de la Auditoría y recolección de evidencias.
- El Informe de Auditoría: comunicando los resultados.
- El Seguimiento del informe: cerrando el ciclo de mejora.

La evaluación consta de cinco secciones que combinan preguntas teóricas, casos prácticos contextualizados en Nicaragua, análisis de situaciones reales y ejercicios de reflexión. El objetivo no es solo memorizar conceptos, sino demostrar la capacidad para aplicarlos en contextos profesionales concretos.

Sección 1: Preguntas de Selección Múltiple (20 puntos)

Instrucciones: Selecciona la opción que mejor responda cada pregunta. Cada respuesta correcta vale 2 puntos.

1.1. ¿Cuál de las siguientes actividades pertenece a la fase de **planeación** de la auditoría de TI?

- a) Ejecutar una prueba de recorrido (walkthrough) sobre el proceso de facturación.
- b) Redactar el resumen ejecutivo del informe final.
- c) Definir el alcance, los objetivos y el programa de trabajo.
- d) Verificar que las recomendaciones hayan sido implementadas por la gerencia.

1.2. Un auditor, al planificar su trabajo, decide concentrar sus recursos en revisar el módulo de transferencias bancarias porque considera que es el área con mayor exposición a fraudes. ¿Qué tipo de enfoque está aplicando?

- a) Enfoque sistémico.
- b) Enfoque basado en riesgos.
- c) Enfoque de cumplimiento.
- d) Enfoque de controles generales.

1.3. Durante el trabajo de campo, un auditor selecciona una muestra de 40 facturas y verifica que cada una tenga la firma de autorización del gerente de ventas, tal como lo establece la política de la empresa. ¿Qué tipo de prueba está realizando?

- a) Prueba sustantiva.
- b) Prueba de cumplimiento (o de controles).
- c) Prueba de recorrido (walkthrough).
- d) Entrevista.

1.4. El uso del software **ACL** o **IDEA** para identificar pagos duplicados a proveedores en una base de datos de cuentas por pagar es un ejemplo de:

- a) Una entrevista estructurada.
- b) Una Técnica de Auditoría Asistida por Computadora (CAATT).
- c) Una observación directa.
- d) Una prueba de recorrido.

1.5. En la estructura de un hallazgo de auditoría, la frase *"La política de seguridad de la empresa establece que las contraseñas deben cambiarse cada 60 días"* corresponde al atributo de:

- a) Condición.
- b) Criterio.
- c) Causa.
- d) Efecto.

1.6. ¿A quién está dirigido principalmente el **Resumen Ejecutivo** de un informe de auditoría de TI?

- a) A los administradores de bases de datos y programadores.
- b) A la Alta Dirección y al Comité de Auditoría.
- c) A los usuarios finales de los sistemas.
- d) A los proveedores externos de servicios tecnológicos.

1.7. ¿Cuál es el objetivo principal de la **reunión de cierre** (o lectura de borrador) con el auditado?

- a) Iniciar formalmente la auditoría y solicitar la documentación inicial.
- b) Negociar los honorarios de la auditoría.
- c) Validar los hechos (condición) de los hallazgos y acordar un plan de acción.
- d) Definir los objetivos y el alcance de la siguiente auditoría.

1.8. Durante la fase de **seguimiento**, el auditor comprueba que una recomendación no ha sido implementada por la gerencia a pesar de haber expirado el plazo acordado. ¿Cuál es la acción profesional que debe tomar el auditor?

- a) Implementar él mismo la recomendación para solucionar el problema.
- b) Reiterar el hallazgo en el próximo informe de auditoría.
- c) Eliminar el hallazgo del informe original.
- d) Extender el plazo sin consultar a la gerencia.

1.9. ¿Cuál de los siguientes NO es un componente típico de los **papeles de trabajo** de auditoría?

- a) El nombre del auditor que realizó el procedimiento y la fecha.
- b) El objetivo del procedimiento ejecutado.
- c) La opinión personal del auditor sobre el desempeño del auditado.
- d) La evidencia recolectada y la conclusión del procedimiento.

1.10. En el contexto de una auditoría gubernamental en Nicaragua, ¿cuál de los siguientes sería un ejemplo de **criterio de auditoría**?

- a) El informe de auditoría del año anterior.
- b) Las Normas de Auditoría Gubernamental de Nicaragua (NAGUN).
- c) El software IDEA utilizado para el análisis de datos.
- d) El bajo presupuesto asignado al departamento de TI.

Sección 2: Términos Pareados (15 puntos)

Instrucciones: Relaciona cada concepto de la columna izquierda con su descripción correcta en la columna derecha. Escribe la letra correspondiente en el paréntesis. Cada relación correcta vale 1.5 puntos.

CONCEPTO	DESCRIPCIÓN
2.1. ALCANCE ()	A. Secuencia detallada de pasos para aplicar una técnica de auditoría.
2.2. PROGRAMA DE TRABAJO ()	B. Atributo del hallazgo que responde a "¿qué consecuencia tiene?".
2.3. PRUEBA DE CUMPLIMIENTO ()	C. Documento que define los límites de la auditoría (procesos, sistemas, período).
2.4. CAATT ()	D. Fase donde se verifica la implementación de las recomendaciones.
2.5. CONDICIÓN ()	E. Herramienta informática para análisis de datos en auditoría (ej. ACL, IDEA).
2.6. CRITERIO ()	F. Prueba diseñada para verificar que un control opera de manera efectiva.
2.7. EFECTO ()	G. Atributo del hallazgo que responde a "¿qué es lo que está mal?".
2.8. REUNIÓN DE CIERRE ()	H. Documento que lista los procedimientos detallados a ejecutar en el trabajo de campo.
2.9. SEGUIMIENTO ()	I. Foro para validar los hallazgos preliminares con el auditado antes del informe final.

2.10. PAPELES DE TRABAJO ()

J. La norma, política o estándar contra el cual se compara la evidencia.

Sección 3: Preguntas de Desarrollo Corto (20 puntos)

Instrucciones: Responde de manera clara y concisa cada pregunta. Cada respuesta correcta y bien fundamentada vale 4 puntos.

3.1. Explica brevemente la diferencia entre una **prueba de cumplimiento** y una **prueba sustantiva**. Proporciona un ejemplo de cada una en el contexto de una auditoría al sistema de nómina de una empresa.

3.2. Menciona y explica **tres** de las actividades clave que se realizan durante la fase de **planeación** de una auditoría de TI.

3.3. Describe la estructura de los **cinco atributos** de un hallazgo de auditoría (Condición, Criterio, Causa, Efecto, Recomendación) y explica brevemente qué pregunta responde cada uno.

3.4. ¿Por qué es importante la fase de **seguimiento** en el proceso de auditoría de TI? Explica cuál es el rol del auditor en esta etapa.

3.5. ¿Qué son los **papeles de trabajo** y cuáles son al menos tres características que deben tener para ser considerados de calidad?

Sección 4: Casos Prácticos Contextualizados en Nicaragua (30 puntos)

Instrucciones: Analiza cada caso y responde las preguntas planteadas. Demuestra tu capacidad para aplicar los conceptos de la unidad a situaciones reales. Cada caso vale 10 puntos.

Caso 1: La Auditoría en la Cooperativa "Unión y Progreso"

La Cooperativa de Ahorro y Crédito "Unión y Progreso" opera en la ciudad de Jinotega y está supervisada por la **SIBOIF**. El departamento de Auditoría Interna ha decidido realizar una auditoría al sistema de ahorros a plazo fijo. Tú eres el auditor de TI asignado.

Preguntas:

- a) Estás en la fase de **planeación**. ¿Cuáles serían **dos criterios de auditoría** clave que utilizarías, considerando el entorno regulado de la cooperativa? Justifica tu respuesta. (2 puntos)
- b) Ya en el **trabajo de campo**, decides evaluar el control que establece que "todo retiro anticipado de un certificado de ahorro a plazo fijo debe ser autorizado por el Gerente de Sucursal". Describe cómo realizarías una **prueba de cumplimiento** para verificar este control. (3 puntos)
- c) Durante tu revisión, encuentras que el sistema **no guarda ningún registro (log)** de quién consulta el saldo de los certificados de ahorro de los socios. Redacta el hallazgo completo utilizando los atributos de **Condición, Criterio (puedes mencionar una norma general de confidencialidad) y Efecto**. (5 puntos)

Caso 2: El Informe en la Alcaldía de Masaya

La **Contraloría General de la República (CGR)** ha finalizado el trabajo de campo de una auditoría al sistema de permisos de construcción de la **Alcaldía de Masaya**. Uno de los hallazgos más relevantes es que un funcionario del área de atención al cliente tiene la capacidad de aprobar permisos de construcción, cuando esa función corresponde exclusivamente al Director de Urbanismo. El informe está en fase de redacción.

Preguntas:

- a) Al redactar este hallazgo en el informe, ¿en qué atributo del hallazgo mencionarías la **NAGUN** que establece la necesidad de segregación de funciones? (2 puntos)
- b) ¿Cuál sería el **efecto** (riesgo para la alcaldía) que describirías en el informe sobre esta situación? Redáctalo en términos claros para la alta dirección municipal. (3 puntos)
- c) El auditor líder ha programado una **reunión de cierre** con el Alcalde y el Director de Urbanismo. ¿Cuál es el propósito de esta reunión en este contexto específico? ¿Qué se espera obtener de los funcionarios de la alcaldía al finalizarla? (3 puntos)
- d) Menciona **una** recomendación concreta que podría incluir el informe para solucionar este problema. (2 puntos)

Caso 3: El Seguimiento en el Hospital Regional de Estelí

El Hospital Regional de Estelí fue auditado hace un año. En esa auditoría, se encontró que el sistema de expediente clínico electrónico permitía que cualquier médico pudiera ver el historial de **todos** los pacientes del hospital, incluso de aquellos que no estaban bajo su tratamiento directo. La recomendación fue: *"Configurar el sistema para que los médicos solo puedan acceder a los expedientes de los pacientes que están bajo su responsabilidad directa en un momento dado."*

El hospital aceptó la recomendación y se comprometió a implementarla en un plazo de 6 meses. Ahora, tú como auditor de seguimiento, regresas un año después para verificar el cumplimiento.

Preguntas:

- a) ¿Qué **evidencia objetiva** solicitarías para verificar que la recomendación fue **implementada** (que existe la nueva configuración)? Menciona al menos dos elementos. (4 puntos)
- b) ¿Qué prueba realizarías para verificar que la recomendación **opera de manera efectiva** (que realmente funciona)? Describe el procedimiento. (4 puntos)
- c) Si descubres que la configuración se implementó, pero que los médicos tienen una forma de "saltársela" usando una cuenta genérica de administrador que no se eliminó, ¿cómo calificarías el estado de esta recomendación (cerrada, en proceso, no implementada/inefectiva)? Justifica tu respuesta. (2 puntos)

Sección 5: Ensayo Corto (15 puntos)

Instrucciones: Redacta un ensayo de una página (aproximadamente 300-400 palabras) que responda a la siguiente pregunta. Se evaluará la claridad de la idea, la estructura del texto, la fundamentación en los conceptos de la unidad y la capacidad de análisis crítico.

Tema del ensayo:

"En el contexto de las organizaciones nicaragüenses, donde a menudo los recursos son limitados y el tiempo es escaso, algunos gerentes podrían considerar que la fase de planeación de una auditoría de TI es una 'pérdida de tiempo' y prefieren 'ir directo al grano' revisando los sistemas. Como auditor profesional, debes convencerlos de lo contrario."

Redacta tu respuesta en forma de ensayo, explicando por qué la fase de planeación es una **inversión** y no un gasto. Tu ensayo debe:

- Definir brevemente en qué consiste la fase de planeación y sus principales actividades.
- Explicar al menos **tres beneficios concretos** de realizar una planeación adecuada (por ejemplo, cómo ayuda a enfocar recursos limitados en áreas de mayor riesgo, cómo evita malentendidos con el auditado, cómo asegura que no se omitan áreas críticas).
- Utilizar un **ejemplo contextualizado en Nicaragua** (real o hipotético) para ilustrar cómo una auditoría sin planeación podría fallar en detectar un riesgo importante, mientras que una auditoría planeada sí lo identificaría.
- Concluir con una reflexión sobre la relación costo-beneficio de invertir tiempo en la planeación.

Criterios de Evaluación

SECCIÓN	PUNTAJE	CRITERIOS DE EVALUACIÓN
SECCIÓN 1: SELECCIÓN MÚLTIPLE	20 puntos	Respuestas correctas según la clave.
SECCIÓN 2: TÉRMINOS PAREADOS	15 puntos	Correspondencia correcta entre conceptos y descripciones.
SECCIÓN 3: DESARROLLO CORTO	20 puntos	Claridad, precisión y fundamentación en los conceptos de la unidad (4 puntos cada pregunta).
SECCIÓN 4: CASOS PRÁCTICOS	30 puntos	Capacidad para aplicar los conceptos a situaciones concretas, justificación de las respuestas, identificación correcta de problemas y soluciones (10 puntos cada caso).
SECCIÓN 5: ENSAYO CORTO	15 puntos	Claridad de la tesis, estructura del ensayo, solidez de los argumentos (fundamentados en la unidad), ejemplos contextualizados, y conclusión reflexiva.
TOTAL	100 puntos	

Bibliografía y Webgrafía

- Piattini Velthuis, M. G., Del Peso Navarro, E. y Del Peso Ruiz, M. (2024). Auditoría de Tecnologías y Sistemas de Información. RA-MA Editorial.
- Ruiz Peña, M. (2024). Auditoría de seguridad informática. Ediciones Paraninfo.
- Fernández Climent, E. (2024). Implementación COBIT 2019: Guía paso a paso. Publicación Independiente.
- Fernández Climent, E. (2024). *ISO/IEC 27001:2022 Paso a Paso: Implementación, Auditoría y Mejora Continua*. Publicación Independiente.
- Mantilla Blanco, S. A. (2023). Control interno y fraudes: Análisis de Informe COSO I, II y III con base en los ciclos transaccionales (3.ª ed.). ECOE Ediciones.
- Contraloría General de la República de Nicaragua. (2023). Normas de Auditoría Gubernamental de Nicaragua (NAGUN). Resolución N.º DGIDCA/DIDI/OINT/NOR-n.º 01-2023, aprobada el 20 de abril de 2023. La Gaceta, Diario Oficial N.º 96 del 1 de junio de 2023.

Alcance de la Auditoría: Límites definidos de una auditoría, especificando qué procesos, sistemas, ubicaciones físicas, períodos de tiempo y actividades serán objeto de revisión. Responde a la pregunta "¿Hasta dónde vamos a revisar?".

Atributos del Hallazgo: Elementos que debe contener un hallazgo de auditoría para ser completo y útil: Condición, Criterio, Causa, Efecto y Recomendación. Constituyen la estructura estándar para documentar desviaciones.

CAATT (Técnicas de Auditoría Asistidas por Computadora): Herramientas y programas informáticos utilizados por el auditor para analizar grandes volúmenes de datos, probar controles y extraer evidencia de los sistemas. Incluyen software como ACL, IDEA, scripts SQL, escáneres de vulnerabilidades y analizadores de logs.

Causa: Atributo del hallazgo que identifica la razón fundamental o raíz que origina la condición encontrada. Responde a la pregunta "¿Por qué ocurrió?".

Condición: Atributo del hallazgo que describe la situación real o fáctica encontrada por el auditor durante su revisión. Es la evidencia de "lo que es" o "lo que está mal".

Criterio de Auditoría: Norma, estándar, política, ley o procedimiento contra el cual el auditor compara la condición encontrada para determinar si existe una desviación. Responde a la pregunta "¿Qué debe ser?". Ejemplos: ISO 27001, NAGUN, Política Interna de Seguridad.

Efecto: Atributo del hallazgo que describe el impacto real o potencial (riesgo) que la condición tiene sobre los objetivos de la organización. Responde a la pregunta "¿Qué consecuencia tiene?".

Enfoque de Auditoría: Estrategia o perspectiva adoptada para realizar una auditoría, determinando dónde se concentrarán los esfuerzos y recursos. El más común es el enfoque basado en riesgos, que prioriza las áreas de mayor exposición.

Evidencia de Auditoría: Información recolectada y documentada por el auditor durante el trabajo de campo que respalda sus hallazgos y conclusiones. Puede ser documental, testimonial, física o analítica. Debe ser suficiente y competente.

Hallazgo de Auditoría: Resultado de la comparación entre la condición encontrada y el criterio aplicable. Es una desviación, debilidad, oportunidad de mejora o irregularidad identificada durante el trabajo de campo.

Informe de Auditoría: Producto final tangible del proceso de auditoría. Documento formal que comunica los objetivos, alcance, hallazgos, conclusiones y recomendaciones del auditor a las partes interesadas. Incluye un Resumen Ejecutivo dirigido a la Alta Dirección.

Objetivos de la Auditoría: Enunciados que definen el propósito específico de la revisión. Responde a la pregunta "¿Qué queremos lograr con esta auditoría?". Deben ser claros y medibles.

Papeles de Trabajo: Conjunto de documentos (físicos o electrónicos) preparados y obtenidos por el auditor durante el curso de la auditoría. Constituyen el soporte probatorio de todo el trabajo realizado y respaldan los hallazgos y conclusiones. Deben ser claros, completos, objetivos y referenciados.

Plan de Acción de la Gerencia: Documento formal elaborado por la gerencia del área auditada que detalla cómo, cuándo y quién implementará las recomendaciones del auditor. Es la base para la fase de seguimiento.

Planeación de la Auditoría: Primera y más crucial fase del proceso de auditoría, donde se define el alcance, los objetivos, el enfoque, los criterios, el programa de trabajo y los recursos necesarios. Una planeación sólida es la base para una auditoría eficiente y efectiva.

Programa de Trabajo: Documento detallado que lista, de manera secuencial y organizada, los procedimientos específicos que se ejecutarán durante el trabajo de campo. Incluye la técnica a emplear, el responsable y el tiempo estimado para cada paso.

Prueba de Cumplimiento (o de Controles): Procedimiento de auditoría diseñado para obtener evidencia sobre la efectividad operativa de un control interno. Verifica si el control existe, se aplica y funciona consistentemente durante el período auditado.

Prueba de Recorrido (Walkthrough): Técnica de auditoría que consiste en seguir el rastro de una o pocas transacciones a través del proceso o sistema, desde su origen hasta su destino final. Se utiliza para confirmar el entendimiento del auditor sobre el flujo y los controles existentes.

Prueba Sustantiva: Procedimiento de auditoría diseñado para obtener evidencia directa sobre la integridad, exactitud y validez de los datos o transacciones. Se enfoca en detectar errores o irregularidades en los datos mismos.

Recomendación: Atributo del hallazgo que contiene la sugerencia concreta y viable del auditor para corregir la causa raíz de la condición encontrada y prevenir su recurrencia. Debe ser específica y estar dirigida a un responsable claro.

Reunión de Cierre: Reunión celebrada al finalizar el trabajo de campo, donde el auditor presenta los hallazgos preliminares al auditado. Su propósito es validar los hechos (condición), discutir las causas y efectos, y acordar un plan de acción con fechas de implementación.

Seguimiento de Auditoría: Quinta y última fase del proceso, donde el auditor verifica que las recomendaciones han sido implementadas por la gerencia y que las acciones correctivas han sido efectivas para mitigar los riesgos identificados. Cierra el ciclo de mejora continua.

Trabajo de Campo (Ejecución): Segunda fase del proceso de auditoría, donde se ejecuta el programa de trabajo y se recolecta la evidencia mediante la aplicación de diversas técnicas (entrevistas, observación, pruebas de cumplimiento y sustantivas, CAATTs, etc.).